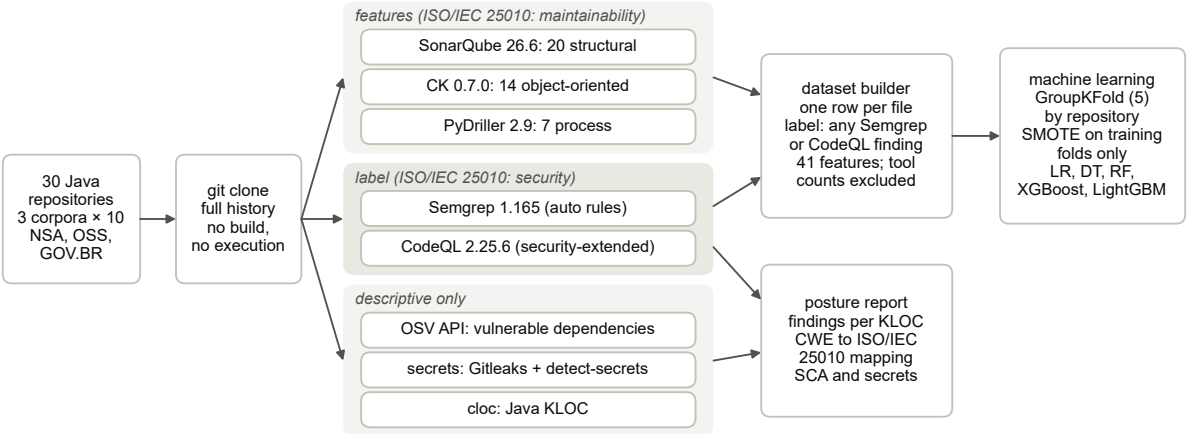
30 Java repositories 3 corpora × 10 NSA, OSS, GOV.BR
git clone full history no build, no execution
features (ISO/IEC 25010: maintainability)
SonarQube 26.6: 20 structural
CK 0.7.0: 14 object-oriented
PyDriller 2.9: 7 process
label (ISO/IEC 25010: security)
Semgrep 1.165 (auto rules)
CodeQL 2.25.6 (security-extended)
descriptive only
OSV API: vulnerable dependencies
secrets: Gitleaks + detect-secrets
cloc: Java KLOC
dataset builder one row per file label: any Semgrep or CodeQL finding 41 features; tool counts excluded
posture report findings per KLOC CWE to ISO/IEC 25010 mapping SCA and secrets
machine learning GroupKFold (5) by repository SMOTE on training folds only LR, DT, RF, XGBoost, LightGBM